

TALLER DE ANÁLISIS DE RIESGOS

Arquitectura Empresarial

Pecker Nutrition S.A.S.

Este documento presenta el análisis de riesgos en Arquitectura Empresarial para Pecker Nutrition S.A.S., empresa dedicada a la comercialización de concentrado para animales (avicultura, porcicultura y ganadería). Se identifican riesgos en los dominios de negocio, procesos, datos, aplicaciones, infraestructura, seguridad y gobierno TI, con su respectiva matriz de evaluación y propuestas de mitigación alineadas a la arquitectura TO-BE.

INTEGRANTES DEL EQUIPO

Luisa Carpintero

Daniel Martin

Nicholas Triana

1. CONTEXTO DEL NEGOCIO

Pecker Nutrition S.A.S. es una empresa colombiana dedicada a la comercialización de concentrado para animales en los segmentos de avicultura, porcicultura y ganadería. Su modelo operativo se apoya en la recepción de pedidos principalmente a través de WhatsApp, gestionados por un bot conversacional y operadores comerciales humanos.

Actores del sistema

- Cliente (avicultor, porcicultor, ganadero)
- Bot de WhatsApp (canal principal de pedidos)
- Operador comercial
- Sistema de facturación
- Banco (integración de pagos)
- ERP de producción
- Sistema de logística

Objetivos estratégicos

- Automatizar el ciclo de ventas desde el pedido hasta la facturación.
- Soportar pedidos recurrentes y fórmulas personalizadas por cliente.
- Garantizar trazabilidad completa del ciclo comercial.
- Escalar hacia integración con ERP y logística.
- Reducir dependencia operativa en procesos manuales.

2. ARQUITECTURA AS-IS

La arquitectura actual de Pecker Nutrition S.A.S. se caracteriza por un modelo de datos relacional normalizado que soporta el flujo comercial completo. Las entidades principales y sus decisiones de diseño se describen a continuación.

Entidades del modelo de datos

Entidad	Propósito	Decisiones clave
Cliente	Actor comercial principal	telefono_whatsapp único; tipo_cliente para segmentación; estado para inactivos sin borrar historial
Dirección	Múltiples direcciones por cliente	Relación 1:N; campo es_principal para dirección predeterminada
Fórmula Personalizada	Mezclas específicas por cliente	Relación 1:N; estado vigente/no vigente; reutilizable en múltiples pedidos

Entidad	Propósito	Decisiones clave
Pedido	Intención comercial del cliente	Canal WhatsApp/teléfono; estados (borrador, confirmado, despachado); soporte a recurrencia
Detalle Pedido	Desglose de productos/fórmulas	Puede referenciar producto estándar o fórmula personalizada (nullable)
Factura	Documento contable	Relación 1:1 con pedido; separada para crédito y validaciones
Pago	Registro de transacciones	Relación 1:N con factura; soporte a abonos; campo respuesta_bot para conciliación

Flujo comercial actual

- 1. Cliente inicia conversación por WhatsApp.
- 2. Sistema valida número de teléfono contra BD de clientes.
- 3. Bot consulta pedidos recurrentes del cliente.
- 4. Cliente confirma o modifica el pedido.
- 5. Sistema genera registro de Pedido y Detalle.
- 6. Sistema crea Factura asociada.
- 7. Cliente realiza Pago; se registra en BD.
- 8. Sistema notifica a logística para despacho.
- 9. Integración con ERP de producción.

3. IDENTIFICACIÓN DE RIESGOS POR DOMINIO

3.1 Riesgos de Negocio

El negocio de Pecker Nutrition depende críticamente del canal WhatsApp y del bot conversacional. Cualquier interrupción en este canal impacta directamente el volumen de ventas.

- Dependencia total del canal WhatsApp: si la plataforma sufre caídas o cambia sus políticas de API, el negocio pierde su único canal principal de pedidos.
- Falta de un canal alternativo formal documentado (web, app móvil, portal de clientes).
- Proceso de atención escalable a humano no estructurado: no existe definición clara del SLA de respuesta cuando el bot escala al operador.
- Segmentación de clientes (avicultura, porcicultura, ganadería) sin estrategia diferenciada de precios o productos en el sistema.
- Dependencia de conocimiento en operadores comerciales para casos no automatizados.

3.2 Riesgos de Procesos

El flujo actual combina automatización (bot) con intervención manual (operador). Esta hibridación genera puntos de riesgo en la trazabilidad y consistencia del proceso.

- Ausencia de BPMN formal documentado: los procesos dependen de conocimiento tácito del equipo.
- Escalada bot → humano sin protocolo definido: riesgo de pérdida de contexto de la conversación.
- Validación de pedidos recurrentes dependiente del historial de WhatsApp: no existe lógica de negocio formal para recurrencia.
- Sin mecanismo de aprobación para fórmulas personalizadas nuevas antes de enviar a producción.
- Proceso de conciliación de pagos (respuesta_bot) manual o semi-automático, con riesgo de errores.
- Falta de proceso documentado para manejo de pedidos anulados o devueltos.

3.3 Riesgos de Datos

El modelo de datos está normalizado (3FN), lo cual es positivo. Sin embargo, existen riesgos asociados a la calidad, gobierno y seguridad de los datos.

- Sin gobierno de datos formal: no existen políticas de retención, calidad ni clasificación de datos.
- Datos financieros (facturas, pagos) en la misma base sin esquemas de cifrado en reposo documentados.
- Campo precio_unitario y subtotal opcionales en Detalle Pedido: puede generar inconsistencias entre pedido y factura.
- Historial de fórmulas personalizadas sin versioning formal: riesgo de aplicar fórmula desactualizada.
- Sin integración directa con ERP: los datos de producción y los datos comerciales pueden desincronizarse.
- Ausencia de política de backup y recuperación de datos documentada.
- Datos de clientes con número WhatsApp como identificador único: cambio de número genera pérdida de historial.

3.4 Riesgos de Aplicaciones

La arquitectura de aplicaciones depende del bot de WhatsApp como capa de presentación principal, con integraciones pendientes hacia ERP y logística.

- Bot de WhatsApp como único punto de entrada: SPAF (Single Point of Application Failure) para pedidos.
- Integración con ERP de producción no implementada aún: operación manual o desconectada.
- Integración con sistema de logística pendiente: riesgo de descoordinación entre despacho y pedido.
- Sin API Gateway centralizado: las integraciones futuras carecen de punto de control unificado.
- Falta de versionamiento de APIs: cambios en el bot o ERP pueden romper integraciones existentes.
- Sin mecanismo de retry o dead-letter queue para mensajes fallidos del bot.
- Posible acoplamiento rígido entre el bot y la estructura de la base de datos.

3.5 Riesgos de Infraestructura

No se dispone de información detallada sobre la infraestructura actual, lo cual es en sí mismo un riesgo de gobierno. Se infieren los siguientes riesgos basados en el contexto de una empresa en etapa de crecimiento.

- Probable arquitectura monolítica en servidor único: SPOF (Single Point of Failure) crítico.
- Sin documentación de arquitectura de infraestructura (topología de red, servidores, cloud vs. on-premise).
- Sin plan de continuidad de negocio (BCP) o recuperación ante desastres (DRP) documentado.
- Ausencia de monitoreo y alertas en tiempo real sobre disponibilidad del sistema.

- Sin métricas de capacidad: desconocimiento del límite de pedidos concurrentes que el sistema puede manejar.
- Respallos de base de datos no documentados ni verificados periódicamente.

3.6 Riesgos de Seguridad

El manejo de datos financieros, NIT de clientes y comunicación por WhatsApp implica obligaciones de seguridad y cumplimiento normativo en Colombia (Ley 1581 de 2012 – Habeas Data).

- Sin política documentada de autenticación y autorización para operadores del sistema.
- Datos personales de clientes (NIT, teléfono, dirección) sin clasificación ni controles de privacidad formales.
- Comunicación bot-backend potencialmente sin cifrado TLS verificado.
- Sin auditoría de accesos: no existe registro de quién consulta o modifica datos sensibles.
- Riesgo de suplantación en WhatsApp: un tercero podría hacerse pasar por un cliente si obtiene el número.
- Sin política de gestión de secretos (API keys, tokens de WhatsApp Business API).
- Incumplimiento potencial de la Ley 1581/2012 por falta de política de protección de datos.

3.7 Riesgos de Gobierno TI

La ausencia de estructuras formales de gobierno de TI representa uno de los riesgos más transversales para la organización en su etapa actual.

- Sin arquitectura de referencia documentada para guiar decisiones tecnológicas futuras.
- Sin proceso formal de gestión de cambios: modificaciones al sistema sin control de impacto.
- Decisiones tecnológicas centralizadas en pocas personas sin documentación de ADR (Architecture Decision Records).
- Sin KPIs tecnológicos definidos: imposible medir el desempeño del sistema de forma objetiva.
- Ausencia de proceso de gestión de incidentes y problemas tecnológicos.
- Sin roadmap tecnológico alineado a la estrategia de negocio.

4. MATRIZ DE RIESGOS

La siguiente matriz consolida los riesgos identificados, evaluados por impacto y probabilidad, con su dominio de arquitectura afectado y la mitigación propuesta.

#	Riesgo	Causa	Impacto	Prob.	Dominio afectado	Mitigación propuesta
1	Caída del canal WhatsApp	Dependencia de plataforma de tercero	Crítico	Alta	Negocio / Aplicaciones	Canal alternativo (portal web) + SLA con Meta/WhatsApp Business
2	SPOF en infraestructura	Probable servidor único sin redundancia	Crítico	Mediana	Infraestructura	Arquitectura cloud con réplica activa-pasiva y DRP documentado
3	Integración ERP no implementada	Desarrollo pendiente	Alto	Alta	Aplicaciones / Datos	API REST con contrato formal + middleware de integración
4	Sin gobierno de datos	Ausencia de políticas formales	Alto	Alta	Datos / Gobierno TI	Implementar Data Governance: clasificación, retención y calidad
5	Suplantación de cliente en WhatsApp	Identificación sólo por número telefónico	Alto	Mediana	Seguridad	OTP de verificación + segundo factor para pedidos de alto valor
6	Pérdida de historial por cambio de número	PK lógica basada en teléfono	Alto	Mediana	Datos	Agregar id_cliente como PK absoluta; teléfono como dato mutable
7	Sin monitoreo de aplicaciones	Ausencia de observabilidad	Alto	Alta	Infraestructura / Gobierno TI	Implementar APM (Application Performance Monitoring) y alertas
8	Datos financieros sin cifrado en reposo	Falta de política de seguridad	Alto	Mediana	Seguridad / Datos	Cifrado AES-256 en BD + TLS 1.3 en tránsito
9	Sin gestión de cambios formal	Procesos no documentados	Medio	Alta	Gobierno TI	Implementar CAB (Change Advisory Board) y control de versiones
10	Escalada bot→humano sin protocolo	Proceso no definido	Medio	Alta	Procesos	Definir BPMN de escalada + handoff de contexto al operador
11	Precio opcional en Detalle Pedido	Decisión de diseño de BD	Medio	Mediana	Datos	Validación de negocio obligatoria antes de crear factura

#	Riesgo	Causa	Impacto	Prob.	Dominio afectado	Mitigación propuesta
12	Sin política de backup verificado	Ausencia de procedimientos	Crítico	Baja	Infraestructura	Backups automáticos diarios + prueba mensual de restauración
13	Incumplimiento Ley 1581/2012	Sin política de privacidad formal	Alto	Medio	Seguridad / Legal	Política de tratamiento de datos + consentimiento explícito
14	Sin versionamiento de APIs	Ausencia de gobierno de APIs	Medio	Medio	Aplicaciones	API Gateway con versionamiento semántico y deprecación formal
15	Sin KPIs tecnológicos	Falta de métricas de desempeño	Bajo	Alta	Gobierno TI	Dashboard de métricas: uptime, tiempo de pedido, errores del bot

● Crítico

● Alto

● Medio

● Bajo

Leyenda de impacto

5. GAP ANALYSIS – AS-IS vs TO-BE

El análisis de brechas permite visualizar la distancia entre el estado actual de la arquitectura y el estado futuro deseado en cada dominio.

Dominio	Estado AS-IS (Actual)	Brecha	Estado TO-BE (Objetivo)
Negocio	Canal único WhatsApp; pedidos semi-manuales	Alta	Multicanal: WhatsApp + portal web; automatización completa
Procesos	Sin BPMN formal; escalada sin protocolo	Alta	Procesos documentados en BPMN; SLA de escalada definido
Datos	Sin gobierno de datos; precios opcionales en BD	Alta	Data Governance implementado; integridad referencial total
Aplicaciones	Bot como único punto de entrada; ERP sin integrar	Crítica	API Gateway; integración ERP y logística vía microservicios
Infraestructura	Probable SPOF; sin monitoreo documentado	Crítica	Cloud redundante; APM; DRP documentado y probado
Seguridad	Sin políticas formales; datos sin cifrar en reposo	Alta	Cifrado, autenticación MFA, auditoría de accesos, Ley 1581
Gobierno TI	Sin ADR; sin gestión de cambios formal	Media	Arquitectura de referencia; CAB; roadmap tecnológico alineado

6. PROPUESTA DE ARQUITECTURA TO-BE

La arquitectura objetivo busca mitigar los riesgos identificados, incrementar la resiliencia y habilitar el crecimiento sostenido de Pecker Nutrition S.A.S.

■ Capa de Canales Multicanal

- WhatsApp Business API como canal principal (con contrato SLA formal con proveedor).
- Portal web de autogestión para clientes (pedidos, historial, facturas).
- App móvil progresiva (PWA) como canal complementario a futuro.

■ API Gateway Centralizado

- Punto único de entrada para todas las integraciones.
- Autenticación OAuth 2.0 + JWT para todos los servicios.
- Versionamiento semántico de APIs (v1, v2...).
- Rate limiting y monitoreo de consumo de APIs.

■ Capa de Servicios (Microservicios o Módulos Desacoplados)

- Servicio de Pedidos (gestión de pedidos y recurrencia).
- Servicio de Clientes y Fórmulas (CRM básico).
- Servicio de Facturación (integración con DIAN para factura electrónica).
- Servicio de Pagos (integración bancaria).
- Servicio de Notificaciones (WhatsApp, email, SMS).

■ Integración con ERP y Logística

- Integración vía API REST con ERP de producción (pedidos → órdenes de producción).
- Webhook para notificación de despacho desde sistema logístico.
- Message broker (e.g., RabbitMQ o AWS SQS) para desacoplamiento asíncrono.

■ Infraestructura Cloud Redundante

- Despliegue en nube pública (AWS, Azure o GCP) con zonas de disponibilidad.
- Base de datos gestionada con réplica de lectura y failover automático.
- CDN para activos estáticos del portal web.
- Backups automáticos diarios con prueba mensual de restauración.

■ Observabilidad y Monitoreo

- APM (Application Performance Monitoring): tiempos de respuesta, errores, throughput.
- Logging centralizado (ELK Stack o equivalente cloud).
- Alertas automáticas por caída de servicios o errores del bot.
- Dashboard de KPIs: pedidos/hora, tasa de conversión del bot, uptime.

■ Seguridad y Cumplimiento

- Cifrado AES-256 en reposo para datos financieros y personales.
- TLS 1.3 para toda comunicación en tránsito.
- MFA para acceso de operadores al sistema.
- Política de privacidad y consentimiento alineada a Ley 1581/2012.
- Auditoría de accesos y cambios en datos sensibles.

■ Gobierno de Arquitectura

- Architecture Decision Records (ADR) para decisiones tecnológicas.
- Change Advisory Board (CAB) para gestión de cambios.
- Roadmap tecnológico semestral alineado a objetivos de negocio.
- KPIs de TI medidos y reportados mensualmente.

7. PLAN DE MITIGACIÓN PRIORIZADO

Las iniciativas de mitigación se priorizan en tres horizontes temporales según urgencia e impacto.

CORTO PLAZO (0–3 meses)

- ✓ Documentar la arquitectura AS-IS completa (infraestructura, procesos, aplicaciones).
- ✓ Implementar backups automáticos diarios con prueba de restauración.
- ✓ Activar TLS 1.3 en todas las comunicaciones bot-backend.
- ✓ Definir y documentar el protocolo de escalada bot→operador con BPMN.
- ✓ Establecer política de tratamiento de datos (Ley 1581) y consentimiento de clientes.
- ✓ Configurar monitoreo básico de disponibilidad del bot y la base de datos.

MEDIANO PLAZO (3–9 meses)

- ✓ Implementar API Gateway centralizado con autenticación OAuth 2.0.
- ✓ Desarrollar integración formal con ERP de producción vía API REST.
- ✓ Migrar infraestructura a nube con redundancia (mínimo 2 zonas de disponibilidad).
- ✓ Establecer gobierno de datos: clasificación, calidad y retención.
- ✓ Implementar APM y logging centralizado con alertas automáticas.
- ✓ Crear Architecture Decision Records (ADR) para decisiones pasadas y futuras.

LARGO PLAZO (9–18 meses)

- ✓ Desarrollar portal web de autogestión para clientes.
- ✓ Implementar message broker para comunicación asíncrona entre servicios.
- ✓ Refactorizar hacia arquitectura de módulos desacoplados (preparación para microservicios).
- ✓ Implementar facturación electrónica integrada con DIAN.
- ✓ Establecer CAB y proceso formal de gestión de cambios.
- ✓ Definir y ejecutar roadmap tecnológico semestral alineado a estrategia.

8. CONCLUSIONES

■ Riesgo operacional crítico por canal único

La dependencia absoluta del canal WhatsApp representa el riesgo más crítico del negocio. Una interrupción de este canal paraliza completamente las ventas. La implementación de un canal alternativo es la iniciativa de mayor urgencia.

■ Infraestructura como riesgo invisible

La ausencia de documentación sobre la infraestructura actual es en sí misma un riesgo. No es posible gestionar lo que no se conoce. Documentar y migrar hacia cloud redundante debe ser prioridad en el corto-mediano plazo.

■ El modelo de datos es una fortaleza

El ERD normalizado de Pecker Nutrition es técnicamente sólido y bien diseñado. Las decisiones de separar Pedido-Factura-Pago son correctas y soportan el crecimiento. Los ajustes necesarios son menores (precios obligatorios, versioning de fórmulas).

■ Seguridad y cumplimiento legal no negociables

El manejo de datos personales y financieros obliga al cumplimiento de la Ley 1581 de 2012. El incumplimiento puede resultar en sanciones de la SIC. Esta iniciativa debe ejecutarse en el corto plazo sin excepción.

■ La arquitectura TO-BE como habilitador estratégico

La propuesta TO-BE no es únicamente una solución técnica: es un habilitador de crecimiento. Un sistema resiliente, seguro y bien integrado permitirá a Pecker Nutrition escalar su operación, mejorar la experiencia del cliente y tomar decisiones basadas en datos.